

ISMS-Systemdokumentation (ISO/IEC 27001:2022)

Dokument-ID: DOC.ISMS.SMART_RESTAURANT.MASTER.v1	Version: 1.0
Geltungsbereich: Smart Restaurant (Backend, DB, Swing & Web UI)	Stand: 01. Oktober 2026
Klassifizierung: Intern / Auditfähig	Eigentümer: ISMS / Der Dreier

1. Executive Summary

- Prüfbarer Geltungsbereich:** Die ISMS-Systemdokumentation umfasst das komplette Informationssicherheits-Managementsystem für das Vorhaben Smart Restaurant, inkl. Java 17 Backend, SQLite/MariaDB-Datenbanken, Standard-SQL-Queries sowie die Bedien-Frontends (Swing GUI & Web-Frontend).
- ISO 27001:2022 Konformität:** Vollständiges Inhalts- und Kontrollmodell mitsamt Annex-A-Mapping (A.5.1, A.5.2, A.5.9, A.5.10, A.8.2, A.8.3, A.8.15, A.8.25), validierbarem JSON-Schema und lückenloser Traceability.
- Evidenzbasierter Nachweis:** Jedes Kontroll- und Inhaltsfeld ist an konkrete Quellcodedateien (src/com/smartrestaurant/*), Datenbankschemata (smart_restaurant_dump.sql) oder Audit-Artefakte gekoppelt.
- Risikoorientierter Ansatz:** Schutzbedarfe für Vertraulichkeit, Integrität und Verfügbarkeit sind für alle Systemkomponenten definiert und mit Prüfmetriken hinterlegt.

2. Master-Inhaltsstruktur

Section-ID	Bezeichnung	Typ	Minimale Inhalte & Informationsdichte	Audit-Relevanz & Norm-Bezug
SEC.01	Zweck & Geltungsbereich	Pflicht	Eindeutige Abgrenzung der Systeme, Standorte, Rollen und Schnittstellen.	ISO 27001 Cl. 4.3 / A.5.1
SEC.02	Rollen & RACI-Matrix	Pflicht	Zuordnung von Aufgaben (Responsible, Accountable, Consulted, Informed).	ISO 27001 Cl. 5.3 / A.5.2

Section-ID	Bezeichnung	Typ	Minimale Inhalte & Informationsdichte	Audit-Relevanz & Norm-Bezug
SEC.03	Asset- & Informationsinventar	Pflicht	Inventarisierung aller Datenklassen (Mitarbeiter, Bestellungen, Artikel) und System-Assets.	ISO 27001 A.5.9 / A.5.10
SEC.04	Risikobewertung & -behandlung	Pflicht	Risikomatrix mit Wahrscheinlichkeit, Auswirkung, Risikowert und Gegenmaßnahmen.	ISO 27001 Cl. 6.1.2 / Cl. 6.1.3
SEC.05	Technische Kontrollen & Härtung	Pflicht	Konfiguration von Eingabevalidierung, Rollentrennung, SQL-Injection-Schutz (PreparedStatement).	ISO 27001 A.8.2 / A.8.25
SEC.06	Logging & Audit-Trails	Pflicht	Fachliches Protokollmodell (statusprotokoll) für alle Statuswechsel mit Zeitstempel & User-ID.	ISO 27001 A.8.15
SEC.07	Verifikation & Testergebnisse	Pflicht	Automatisierte Integrationstests (DatabaseTest.java) und Nachweis der 100%igen Erfolgsquote.	ISO 27001 A.8.25 / A.8.29

3. Mapping-Tabelle (Inhaltsfeld ↔ Annex-A-Control ↔ Audit-Frage)

Field-ID	Bezeichnung	Pflicht?	Beschreibung (Mindestinhalt)	Audit-Frage	Erwartete Evidenz	Annex A (2022)
FIELD.01	Systemgrenzen	Ja	Exakte Abgrenzung von Java-Backend, Datenbank und UIs.	Ist der Geltungsbereich klar definiert?	SEC.01 / gesamtkonzept.md	A.5.1

Field-ID	Bezeichnung	Pflicht?	Beschreibung (Mindestinhalt)	Audit-Frage	Erwartete Evidenz	Annex A (2022)
FIELD.02	Rollenschema	Ja	Spezifikation der Rollen Service, Küche, Admin.	Werden Zugriffsrechte nach Least-Privilege vergeben?	Mitarbeiter.java / rolle-Tabelle	A.5.2 / A.8.2
FIELD.03	Asset-Katalog	Ja	Inventarisierung der Datenklassen (Mitarbeiter, Artikel, Tische).	Werden alle Informationswerte inventarisiert?	13-datenbank-schema.sql	A.5.9 / A.5.10
FIELD.04	SQL-Injection-Schutz	Ja	Ausschließliche Nutzung von PreparedStatement im DAO.	Ist der Datentransfer vor Manipulation geschützt?	DatabaseManager.java	A.8.25 / A.8.28
FIELD.05	Audit-Protokoll	Ja	Aufzeichnung jeder Statusänderung mit Zeitstempel & Mitarbeiter.	Werden prozessrelevante Aktionen geloggt?	statusprotokoll-Tabelle	A.8.15
FIELD.06	Testnachweis	Ja	Automatisierte Testausführung ohne Fehlschläge.	Werden Änderungen vor Deployment getestet?	DatabaseTest.java Protokoll	A.8.29

4. Audit-Checkliste

Prüffrage-ID	Prüffrage	Erwartete Evidenz	Akzeptanzkriterium	Verantwortlicher
AUD.01	Werden alle SQL-Abfragen frei von String-Konkatenationen ausgeführt?	Quellcode-Review DatabaseManager.java	100 % der dynamischen SQL-Queries nutzen PreparedStatement.	Lead Developer

Prüffrage-ID	Prüffrage	Erwartete Evidenz	Akzeptanzkriterium	Verantwortlicher
AUD.02	Existiert ein fachlicher Audit-Trail für Bestellstatusänderungen?	Datenbank-Dump smart_restaurant_dump.sql	Tabelle statusprotokoll enthält Einträge für jeden Statuswechsel.	Database Admin
AUD.03	Sind alle Abhängigkeiten lückenlos inventarisiert und lizenzkonform?	package-lock.json & lizenzdokumentation.md	Ausschließlich freie Open-Source- Lizenzen (MIT/ISC).	Compliance Officer
AUD.04	Funktioniert der automatisierte Testlauf fehlerfrei?	Testergebnis-Protokoll DatabaseTest.java	Konsolenausgabe zeigt ALLE AUTOMATISIERTEN TESTS ERFOLGREICH BESTANDEN!.	QA Specialist